第 10 章 信息安全管理与审计

本章学习要点：

- 掌握信息安全风险评估流程；
- 了解信息安全管理标准；
- 了解信息安全审计的分类和过程。

10.1 信息安全管理体系

在中小企业服务平台中，信息安全事件除了前面介绍的信息安全技术因素引起的外，另一方面是因管理不当而导致的。据有关统计，信息安全事件中大约有 70%以上的问题都是由于管理方面的原因造成的，即对应于人们常说的“三分技术，七分管理”。因此，仅靠信息安全技术并不能实现信息安全的持续性，只有树立信息安全意识，完善信息安全组织，健全信息安全制度，建立体系化的流程化的信息安全管理机制，规范信息安全行为才能建立信息安全长久机制。

根据木桶原理，信息系统安全水平将由与信息安全有关的所有环节中最薄弱的环节所决定，因此要实现良好的信息安全，需要信息安全技术和信息安全管理进行有效配合。具体而言，在信息安全技术方面，需要建设安全的主机系统和安全的网络系统，包括实现物理层安全、系统层安全、网络层安全和应用层安全等，并配备一定的安全产品，如数据加密产品、数据存储备份产品、系统容错产品、防病毒产品、安全网关产品等。在信息安全管理层面，则需要构建信息安全管理体系。

本节将介绍信息安全管理体系的相关概念、构建方法和过程，以及信息安全管理标准。

10.1.1 信息安全管理体系概念

目前，人们对信息安全管理(information security management)的概念没有统一的定义。一般而言，信息安全管理指组织为了实现信息安全目标和信息资产保护，用来指导和管理各种控制信息安全风险的、一组相互协调的活动。要实现组织中信息的安全性、高效性和动态性管理，就需要依据信息安全管理模型和信息安全管理标准构建信息安全管理体系。

信息安全管理体系(Information Security Management System，ISMS)是组织以信息安全风险评估为基础的系统化、程序化和文件化的管理体系，包括建立、实施、运行、监视、评审、保持和改进信息安全等一系列的管理活动。管理体系通常包括组织结构、方针策略、规划活动、职责、实践、程序、过程和资源。由此可见，ISMS 的建立基于组织，立足于信息安全风险评估，体现以预防为主的思想，并且是全过程和动态控制。一般而言，ISMS 具有如下的功能。

(1) 强化员工的信息安全意识，规范组织的信息安全行为。

(2) 对组织的关键信息资产进行全面系统的保护，维持竞争优势。
(3) 在信息系统受到侵袭时，确保业务持续开展并将损失降到最低程度。
(4) 使组织的生意伙伴和客户对组织充满信心。
(5) 使组织定期地考虑新的威胁和脆弱性，并对系统进行更新和控制。
(6) 促使管理层坚持贯彻信息安全保障体系。

10.1.2　信息安全管理体系构建方法

BS7799 是国际公认的 ISMS 标准，其第二部分 BS7799—2《信息安全管理体系规范》中详细说明了建立、实施和维护信息安全管理体系的要求。一个组织必须识别和管理众多活动使之有效运作。通过使用资源和管理，将输入转化为输出的任意活动，可以视为一个过程。通常，一个过程的输出可直接构成下一个过程的输入。一个组织内各个过程系统的运用，连同这些过程的识别和相互作用及管理，称为“过程方法”。

2002 年，BS7799—2 的修订版本 BS7799—2：2002 中引入了 PDCA (plan-do-check-action)过程方法，用于建立、实施和持续改进 ISMS。PDCA 循环又称“戴明环”，由美国质量管理专家 Edwards Deming 博士在 20 世纪 50 年代提出，是全面质量管理所应遵循的科学程序。PDCA 强调应将业务过程看作连续的反馈循环，在反馈循环的过程中识别需要改进的部分，以使过程得到持续的改进，质量得到螺旋式上升。BS7799—2：2002 标准在建立、实施和改进组织 ISMS 的过程方法中采用了 PDCA 循环的思想，具体如图 10.1 所示。

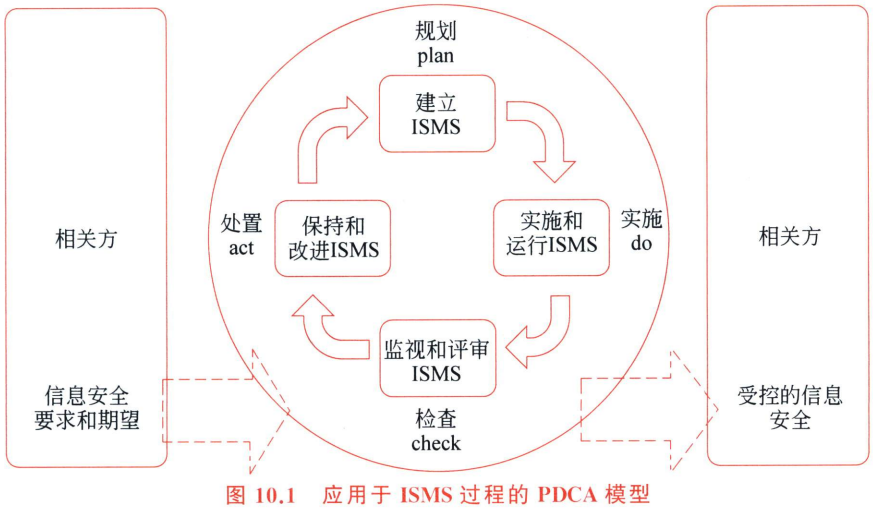


图 10.1　应用于 ISMS 过程的 PDCA 模型

应用于 ISMS 过程的 PDCA 模型在每个阶段的具体内容如下。

1. 规划(plan)

在这个阶段，主要完成 ISMS 的构建工作，主要包括：定义 ISMS 的范围和方针，制定风险评估的系统性方法，识别风险，应用组织确定的系统性方法评估风险，识别并评估可选的风险处理方式，选择控制目标与控制方式，当决定接受剩余风险时应获得管理者同意并获得管理者授权，以及拟定一份适用性声明。

2. 实施(do)

实施阶段主要任务是实施和运行 ISMS 方针、控制措施、过程和程序，包括：实施特定的管理程序，实施所选择的控制，运作管理，实施能够促进安全事件检测和响应的程序和其他控制。

3. 检查(check)

检查阶段的主要任务是进行有关方针、标准、法律法规与程序的符合性检查，包括：ISMS的执行程序及其他控制措施是否得以认真贯彻，ISMS有效性的定期评审，度量控制措施的有效性以验证安全要求是否被满足，按照计划的时间间隔进行风险评估的评审等。

4. 处置(act)

处置阶段主要对ISMS进行评价，寻求改进的机会，采取相应的措施，包括：测量ISMS绩效，识别ISMS的改进措施并有效实施，采取适当的纠正和预防措施，与涉及的所有相关方磋商、沟通结果及其措施，必要时修改ISMS，确保修改达到既定的目标。

10.1.3 信息安全管理体系构建流程

本节主要介绍ISMS构建过程，ISMS框架的搭建是按照适当的流程进行的，具体如图10.2所示。



图10.2 ISMS框架建立流程

1. 定义信息安全方针和策略

信息安全方针是组织信息安全的最高方针，需要根据组织内各个部门的实际情况，分别制定不同的信息安全方针。信息安全方针的制定应遵循简洁明了、通俗易懂的原则，并形成书面文档，发给组织内的所有成员。为了加强组织内相关成员对方针的理解，更好地应用于实际工作中，需要对组织内的相关成员进行信息安全方针培训。

此外，除了总的信息安全方针外，还需要制定具体的信息安全策略，明确规定具体的信息安全实施规则，用来保证控制措施的有效执行。

2. 定义ISMS的范围

组织需要根据自身的特性，如地理位置、资产和技术等，对ISMS的范围进行界定。在本阶段，应将组织划分为不同的信息安全控制领域，以便对不同需求的领域进行适当的信息安全

管理。

3. 进行信息安全风险评估

信息安全风险评估的复杂程度将取决于风险的复杂程度和受保护资产的敏感程度。组织需要选择一个适合其安全要求的风险评估和管理方案，然后进行合乎规范的评估，识别当前面临的风险及风险等级。信息安全风险评估的对象是组织的信息资产，评估内容主要包括对信息资产面临的各种威胁和脆弱性进行评估，同时对已存在的安全措施进行鉴定。更多内容将在 10.2 节中详细介绍。

4. 信息安全风险管理

根据信息安全风险评估结果和结论进行相应的风险管理，将信息安全风险水平降至可接受的范围。主要措施有：降低风险、避免风险、转移风险和接受风险。降低风险是在考虑转移风险之前，首先考虑要采取的措施；对于有些风险，可采用一定的技术措施或更改操作流程实现风险避免；若某些风险不能被降低或避免，在被转嫁风险方接受的情况下，可进行转移风险的操作；在采取了降低风险和避免风险的措施后，出于实际和经济方面的原因，只要组织进行运营，就必然存在并必须接受的风险。

5. 确定控制目标和选择控制措施

控制目标的确定和控制措施的选择的原则是费用不能超过风险所造成的损失。由于信息安全是一个动态的系统工程，组织应实时对选择的控制目标和控制措施加以校验和调整，以适应变化了的情况，使组织的信息资产得到有效、经济、合理的保护。

6. 准备信息安全适用性声明

信息安全适用性声明记录了组织内相关的风险控制目标和针对每种风险所采取的各种控制措施。主要的作用包括：向组织内的成员声明面对信息安全风险的态度；向组织外的人员表明组织的态度和作为，表明组织已经全面、系统地审视了组织的信息安全系统，并将所有应该得到控制的风险控制在能够被接受的范围内。

10.1.4　信息安全管理标准

信息安全管理标准对 ISMS 的建设具有重要的指导意义，本节介绍当前信息安全管理相关的技术标准。

1. BS7799

BS7799 是在英国 BSI/DISC（British Standards Institute/Delivering Information Solutions to Customers）的 BDD/2 信息安全管理委员会指导下完成的，是当前国际公认的信息安全实施标准。该标准旨在为一个组织提供用来制定安全标准、实施有效安全管理的通用要素，并不涉及“怎么做”的细节，它是制定一个机构自己标准的出发点，因此适用于各种产业和组织，其演进发展过程如图 10.3 所示。

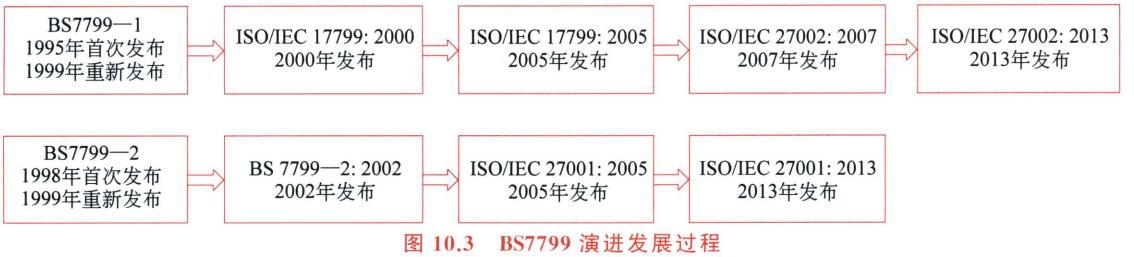


图 10.3　BS7799 演进发展过程

1993年，BS7799标准由英国贸易工业部立项；1995年，英国首次出版BS7799—1：1995《信息安全管理实施细则》；1998年，BS7799—2：1998《信息安全管理体系规范》公布；1999年，BS7799—1：1995和BS7799—2：1998被重新修订，并发布了BS7799—1：1999和BS7799—2：1999，其中BS7779—1：1999对如何建立并实施符合BS7799—2：1999标准要求的ISMS提供了最佳的应用建议；2000年，BS7799—1：1999《信息安全管理实施细则》通过了国际标准化组织ISO认证，正式成为国际标准ISO/IEC 17799—1：2000《信息技术-信息安全管理实施规则》；2002年，BS7799—2：1999被重新修订，并发布了替代版本BS7799—2：2002；2005年，ISO/IEC 17799—1：2000改版，发展成为ISO/IEC 17799：2005标准，BS7799—2：2002也被ISO正式采用，命令为ISO/IEC 27001：2005；2007年，为了和27000系列保持统一，ISO组织将ISO/IEC 17799：2005正式更改编号为ISO/IEC 27002：2005；时隔8年后，ISO/IEC 27002：2005和ISO/IEC 27001：2005被重新修订，于2013年10月正式发布了替代版本ISO/IEC 27002：2013《信息技术-安全技术-信息安全控制实用规则》和ISO/IEC 27001：2013《信息技术-安全技术-信息安全管理体系-要求》。

可见，BS7799发展后分为两部分，这里仍然以ISO/IEC 27002：2005和ISO/IEC 27001：2005为例进行介绍。ISO/IEC 27002：2005标准包含有11项管理内容，133条安全控制措施。在2013年新发布的版本ISO/IEC 27002：2013中，管理内容被调整为14项，控制措施减少到113条。ISO/IEC 27002：2005的安全管理体系如图10.4所示。

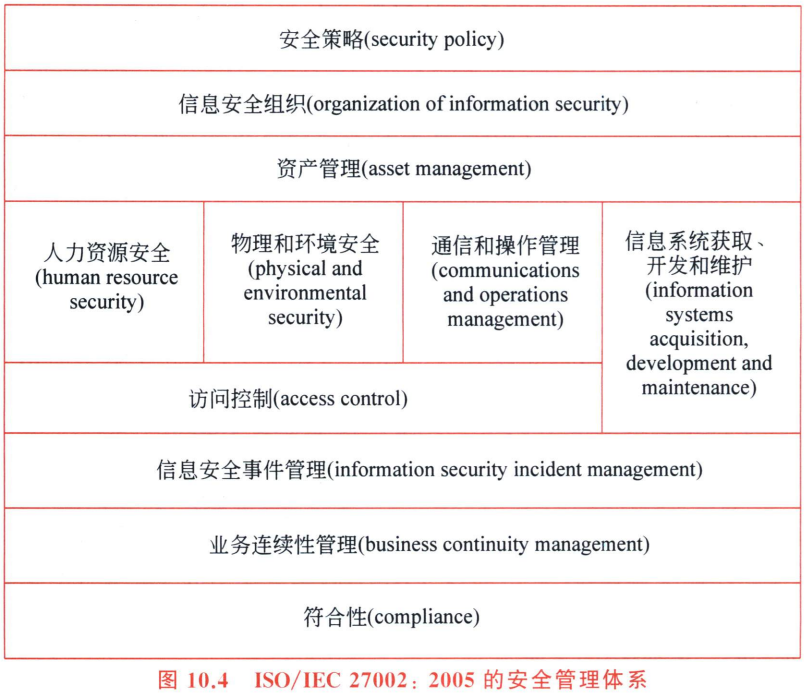


图10.4 ISO/IEC 27002：2005的安全管理体系

ISO/IEC 27001：2005《信息安全管理体系规范》主要讨论了以PDCA过程方法建设ISMS，以及ISMS评估的内容，具体内容已在前面进行了介绍，不再赘述。该标准详细说明了建立、实施、监视和维护ISMS的具体任务和要求，指出实施机构应该遵循的风险评估标准。作为一套标准，ISO/IEC 27001：2005给出了组织如何通过ISO/IEC 27002：2005来建立满足安全需求的ISMS的方法。到目前为止，已知的正式认可的ISMS认证方案是根据ISO/IEC 27001：2005实施的，而不是根据ISO/IEC 27002：2005。

2. 信息和相关技术控制目标

信息和相关技术控制目标(Control Objective for Information and related Technology，COBIT)是目前国际上通用的安全与信息技术管理和控制标准。它在业务风险、控制需要和技术问题之间架起了一座桥梁，可以辅助管理层进行 IT 治理，指导组织有效利用信息资源，有效地管理与信息相关的风险。COBIT 共分为 4 个域，34 个高级控制目标和 318 个详细控制目标，其中 4 个域为：规划与组织(Planning & Organization，PO)、获取与实施(Acquisition & Implementation，AI)、交付与支持(Delivery and Support，DS)、监视和评价(Monitor & Evaluate，ME)。通过这 4 个域，对 IT 资源进行管理，实现 IT 的控制目标，具体如图 10.5 所示。

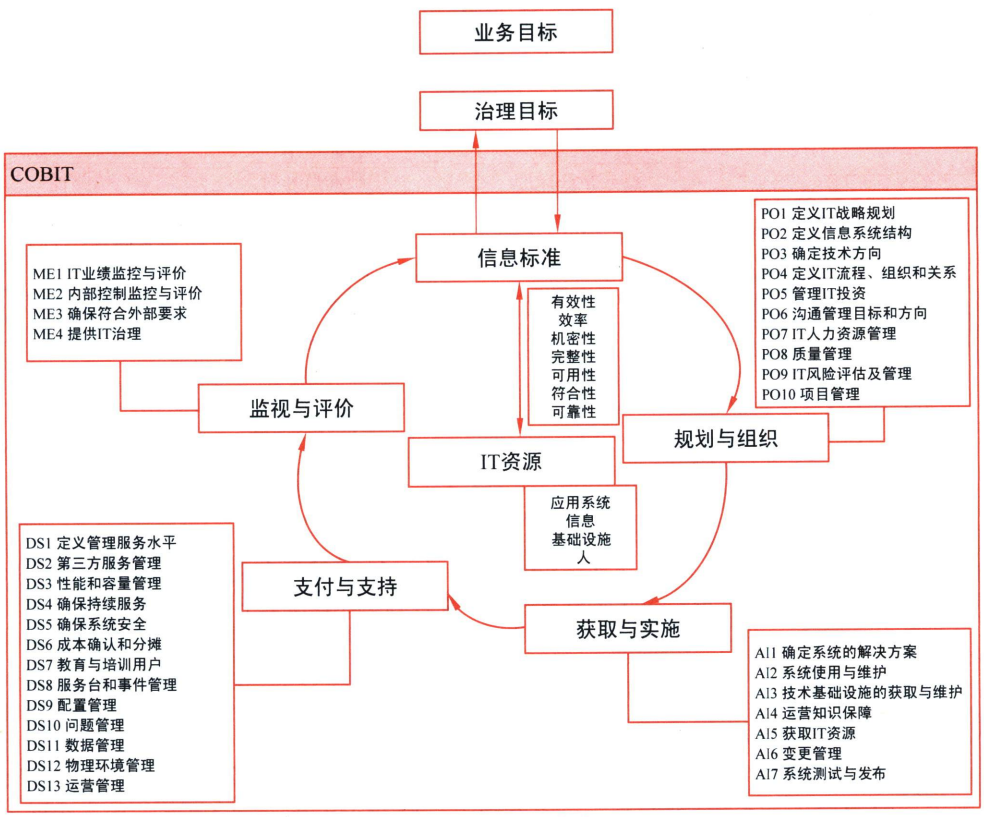


图 10.5　COBIT 框架

3. ISO/IEC 13335

ISO/IEC 13335 是国际标准《IT 安全管理指南》，该标准由 5 部分组成：ISO/IEC 13335—1：1996《IT 安全的概念与模型》、ISO/IEC 13335—2：1997《IT 安全管理与规划》、ISO/IEC 13335—3：1998《IT 安全管理技术》、ISO/IEC 13335—4：2000《防护措施的选择》、ISO/IEC 13335—5：2001《网络安全管理指南》。其中，ISO/IEC 13335—1：1996《IT 安全的概念与模型》已经被新的 ISO/IEC 13335—1：2004《信息和通信技术安全管理的概念和模型》所取代。

4. GB 17859—1999

1999 年，由我国公安部主持制定、国家质量技术监督局发布的中华人民共和国国家标准 GB 17859—1999《计算机信息系统安全保护等级划分准则》正式颁布，于 2001 年 1 月 1 日起施

行。该标准将计算机信息系统安全保护等级划分为5个级别：自主安全保护级、审计保护级、强制安全保护级、结构化保护级和访问验证保护级。这5个级别的划分准则如图10.6所示。



图 10.6 信息系统安全保护等级划分准则

10.2 信息安全风险评估

信息安全风险评估是信息安全管理的基础，也是信息安全管理的核心内容。本节主要介绍信息安全风险评估的相关概念、组成要素、评估流程、评估方法及评估工具。

10.2.1 信息安全风险评估概念

风险(risk)是一定条件下和一定时期内可能发生的不利事件发生的可能性。既强调风险发生的不确定性，又强调风险损失的不确定性。目前，信息安全风险没有统一的定义。在澳大利亚/新西兰国家标准AS/NZS 4360中，信息安全风险指对目标产生影响的某种事件发生的可能性，可以用后果和可能性来衡量。在ISO/IEC 13335—1中，信息安全风险是某个给定的威胁利用单个或一组资产的脆弱性造成资产受损的潜在可能性。在我国GB/T 20984—2022《信息安全技术　信息安全风险评估方法》中，信息安全风险是指人为或自然的威胁利用信息系统及其管理体系中存在的脆弱性导致安全事件的发生及其对组织造成的影响。

一般而言，信息安全风险可表现为威胁(threats)、脆弱性(vulnerabilities)和资产(asset)之间的相互作用，即

$$\text{Risk}=\text{Threats}+\text{Vulnerabilities}+\text{Asset}$$

其中风险会随着任一因素的增加而增大，减少而减少。

根据《信息安全技术　信息安全风险评估方法》，信息安全风险评估指依据有关信息安全技术与管理标准，对信息系统及由其处理、传输和存储的信息的保密性、完整性和可用性等安全属性进行评价的过程。它要评估资产面临的威胁及威胁利用脆弱性导致安全事件的可能

性，并结合安全事件所涉及的资产价值来判断安全事件一旦发生对组织造成的影响。

信息安全风险评估对信息安全保障体系建设具有重要的促进作用，能有效帮助组织制定决策策略。没有有效和及时的信息安全风险评估，将使得各个组织无法对其信息安全的状况作出准确的判断。因为任何信息系统都会有安全风险，信息安全建设的宗旨之一，就是在综合考虑成本和效益的前提下，通过安全措施来控制风险，使残余风险降至用户可控范围内。

10.2.2　信息安全风险评估组成要素

在 CC 标准、ISO 13335 标准和我国的《信息安全技术　信息安全风险评估方法》标准等中都有对信息安全风险的构成要素及相关关系进行描述。本节以这 3 个标准为基础，介绍信息安全风险评估组成要素及其相关关系。

1. CC 标准

1993 年，美国、加拿大同欧洲四国组成六国七方，共同制定了国际通用的评估准则 CC (common criteria)，其目的是建立一个各国都能接受的通用的信息安全产品和系统的安全性评价标准。在 1996 年颁布了 CC1.0 版，1998 年颁布了 CC2.0 版，1999 年，ISO 接纳 CC2.0 版为 ISO/IEC 15408 草案，并命名为《信息技术-安全技术-IT 安全性评估准则》，并于同年正式发布国际标准 ISO/IEC 15408 CC2.1 版。

CC 标准主要由三部分构成：简介和一般模型、安全功能要求、安全保障要求。在简介和一般模型中，定义了信息安全风险构成要素威胁、风险、脆弱性、资产、对策等关键风险要素的概念，同时又提出了所有者和威胁主体的概念，如图 10.7 所示。

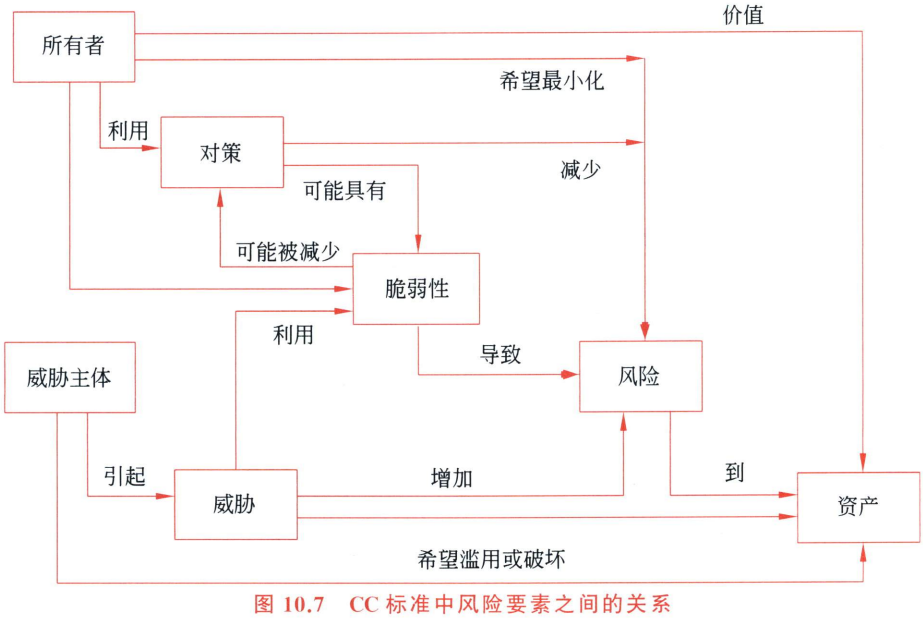


图 10.7　CC 标准中风险要素之间的关系

风险要素之间的关系可概括为如下过程。

(1) 信息资产的所有者给资产赋予了一定的价值，威胁主体希望滥用或破坏资产，因而引发威胁利用脆弱性，导致风险的产生。

(2) 资产所有者意识到脆弱性的存在和脆弱性被利用而导致的风险，因而希望通过对策

来降低风险，使风险最小化。

（3）脆弱性可能被对策减少，但是同时对策本身可能具有其他的脆弱性。

2. ISO 13335 标准和 GB/T 20984—2022 标准

ISO/IEC 13335 是信息安全管理方面的指导性标准，ISO/IEC 13335—1 以风险为中心，确定了资产、威胁、脆弱性、影响、风险、防护措施为信息安全风险的要素，并描述了它们之间的关系，如图 10.8 所示。

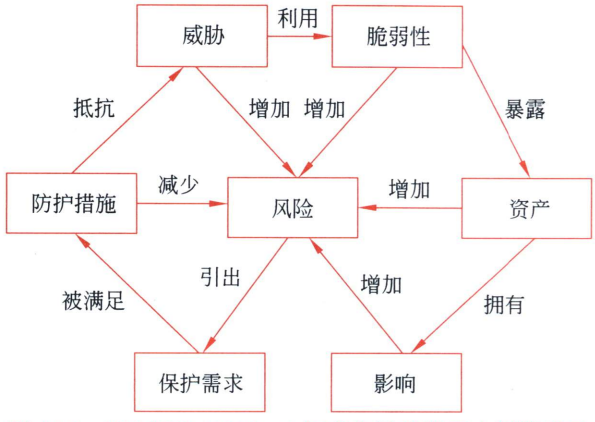


图 10.8 ISO/IEC 13335—1 标准中风险要素之间的关系

我国的 GB/T 20984—2022 标准对该模型进行了深化，具体如图 10.9 所示。风险评估围绕着资产、威胁、脆弱性和安全措施这些基本要素展开，对在基本要素的评估过程中，充分考虑业务战略、资产价值、安全需求、安全事件、残余风险等与这些基本要素相关的各类属性。

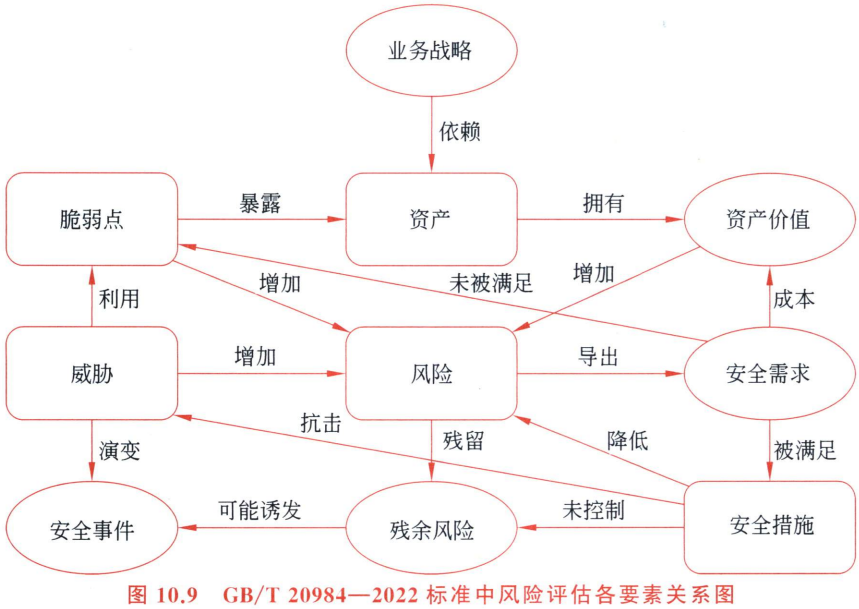


图 10.9 GB/T 20984—2022 标准中风险评估各要素关系图

具体而言，风险要素及属性之间的关系如下。

（1）业务战略的实现对资产具有依赖性，依赖程度越高，要求其风险越小。

（2）资产是有价值的，组织的业务战略对资产的依赖程度越高，资产价值就越大。

（3）风险是由威胁引起的，资产面临的威胁越多则风险越大，并可能演变成安全事件。

(4) 资产的脆弱性可能暴露资产的价值，资产具有的脆弱性越多则风险越大。

(5) 脆弱性是未被满足的安全需求，威胁利用脆弱性危害资产。

(6) 风险的存在及对风险的认识导出安全需求。

(7) 安全需求可通过安全措施得以满足，需要结合资产价值考虑实施成本。

(8) 安全措施可抵御威胁，降低风险。

(9) 残余风险有些是安全措施不当或无效，需要加强才可控制的风险；而有些则是在综合考虑了安全成本与效益后不去控制的风险。

(10) 残余风险应受到密切监视，它可能会在将来诱发新的安全事件。

10.2.3　信息安全风险评估流程



根据我国的 GB/T 20984—2022 标准，详细的风险评估实施流程如图 10.10 所示。

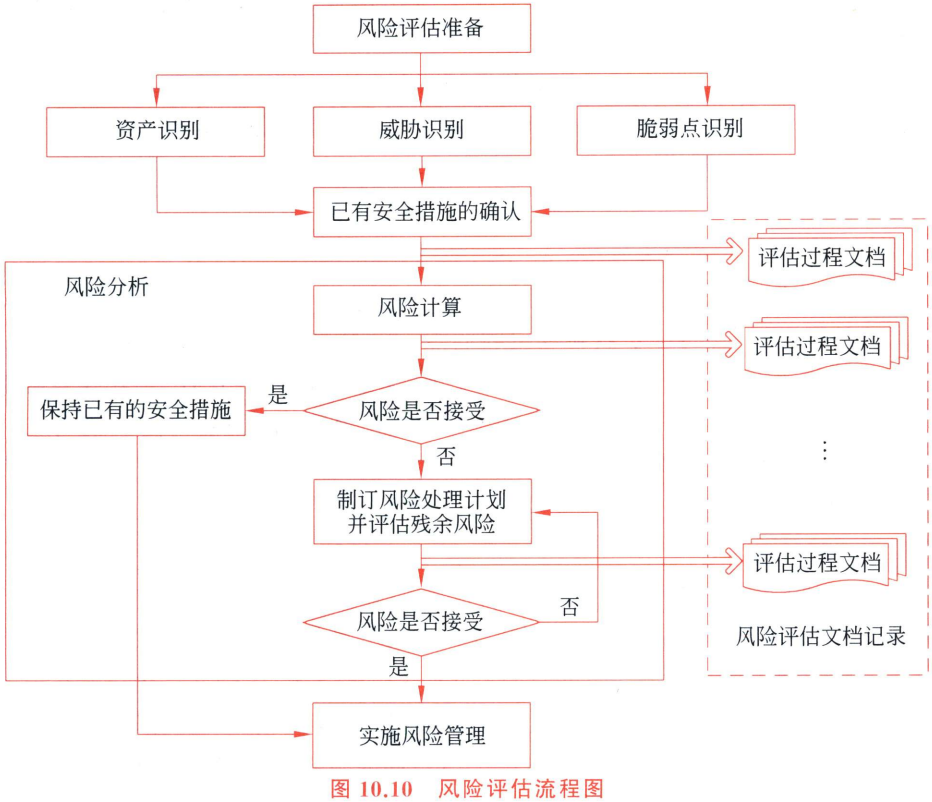


图 10.10　风险评估流程图

1. 风险评估准备

该阶段是整个风险评估过程有效性的保证。组织实施风险评估是一种战略性的考虑，其结果将受到组织的业务战略、业务流程、安全需求、系统规模和结构等方面的影响。因此，在风险评估实施前，应完成的任务有：确定风险评估的目标，确定风险评估的范围，组建适当的评估管理与实施团队，进行系统调研，确定评估依据和方法，制定风险评估方案，获得最高管理者对风险评估工作的支持。

2. 资产识别

该阶段主要完成资产分类、资产赋值两方面的内容。资产分类是进行下一步的基础，在实际工作中，具体的资产分类方法可根据实际情况的需要，由评估值灵活把握。一般而言，根据

资产的表现形式，可将资产分为物理资产、信息资产、软件资产、服务及无形资产等方面。资产赋值是对资产的价值或重要程度进行评估。一般地，资产的价值可由资产在安全属性上的达成程度或其他安全属性未达成时所造成的影响程度来决定，具体可分为保密性赋值、完整性赋值、可用性赋值三方面。然后在此基础上，经过综合评定得到资产重要性等级。当前综合评定的常见方法有加权平均原则、最大化原则等。

3. 威胁识别

该阶段主要完成组织资产面临的威胁识别、威胁赋值两方面的内容。在威胁识别方面，当前不同的手册给出了不同的威胁分类方式，如 ISO/IEC 13335—3、德国的《IT 基线保护手册》、OCTAVE 等。一般地，根据威胁来源，威胁可分为环境威胁和人为威胁，其中环境威胁包括自然界不可抗力威胁和其他物理因素威胁；人为威胁包括恶意和非恶意两种类型。在威胁赋值方面，可以对威胁出现的频率进行等级化处理，不同等级分别代表威胁出现的频率的高低；等级数值越大，威胁出现的频率越高。在形成威胁出现频率的评估中，一般需要考虑如下因素。

（1）以往安全事件报告中出现过的威胁、威胁的频率、破坏力的统计。

（2）实际环境中通过检测工具及各种日志发现的威胁和其频率的统计。

（3）近一两年来国际组织发布的对于整个社会或特定行业的威胁出频率及其破坏力的统计。

4. 脆弱性识别

该阶段主要完成脆弱性识别、脆弱性赋值两方面的内容。在脆弱性识别方面，主要针对每一项需要保护的资产，找出可能被威胁利用的弱点，并对脆弱性的严重程度进行评估。当前，主要从技术和管理两方面进行，技术脆弱性涉及物理层、网络层、系统层、应用层等各个层面的安全问题。管理脆弱性又可分为技术管理脆弱性和组织管理脆弱性两方面，前者与具体技术活动相关，后者与管理环境相关。在脆弱性赋值方面，一般是在脆弱性被利用后对资产损害程度、技术实现的难易程度、弱点流行程度进行评估，然后以定性等级划分形式，综合给出脆弱性的严重程度。

5. 已有安全措施的确认

安全措施一般可分为预防性安全措施和保护性安全措施两种。预防性安全措施可以降低威胁利用脆弱性导致安全事件发生的可能性，如入侵检测系统；保护性安全措施可以减少因安全事件发生后对组织或系统造成的影响。本阶段通过对当前信息系统所采用的安全措施进行标识，有助于对当前信息系统面临的风险进行分析；同时分析其预期功能和有效性，能避免不必要的工作和费用，防止安全措施的重复实施。

6. 风险分析

该阶段主要完成风险计算、风险处理计划、残余风险评估三方面的内容。在风险计算方面，主要通过综合安全事件所作用的资产价值及脆弱性的严重程度，判断安全事件造成的损失对组织的影响，即得到安全风险值，具体过程如图 10.11 所示。

一般地，安全风险可形式化表达为

$$\text{风险值}=R(\mathrm{A},\mathrm{T},\mathrm{V})=R[L(\mathrm{T},\mathrm{V})\times F(I_a,V_a)]$$

式中：R 为风险函数；A、T、V 分别表示资产、威胁和脆弱性；I_a 表示安全事件所作用的资产价值；V_a 表示脆弱性等级大小；L 表示威胁利用资产的脆弱性而导致安全事件的可能性；F 表示安全事件发生后造成的损失。

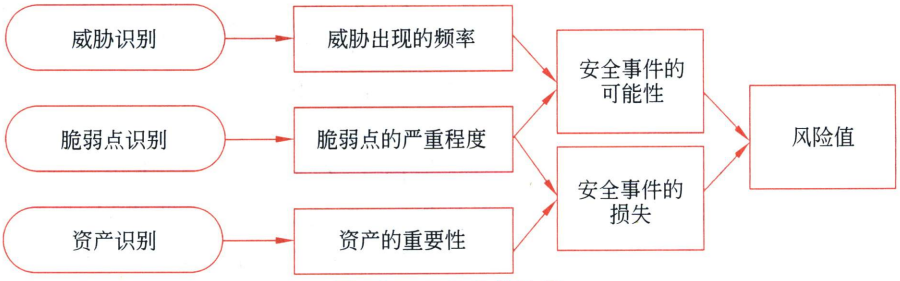


图 10.11　风险值计算

在风险处理计划方面，主要完成对不可接受的风险的处理工作。风险处理计划中应明确采取的弥补脆弱性的安全措施、预期效果、实施条件、进度安排、责任部门等。在残余风险评估方面，主要用来评估在安全措施实施后，残余风险是否降低到可以接受的水平。若仍然不满足风险水平的要求，则需要进一步调整风险处理计划，增加相应的安全措施。

7. 风险评估文档记录

该阶段主要记录在整个风险评估过程中产生的评估过程文档和评估结果文档，包括风险评价计划、风险评估程序、资产识别清单、重要资产清单、威胁列表、脆弱性列表、已有安全措施确认表、风险评估报告、风险处理计划和风险评估记录等。

10.2.4　信息安全风险评估方法与工具

10.2.4.1　信息安全风险评估方法

评估信息安全的风险，首先必须选择适合本信息系统的方法。评估方法是使评估有效的重要因素，它对评估过程中的每个具体的环节都有直接影响。评估方法除了具备较高的可信度外，还要尽可能确保评估指标的量化以便对其更有效的应用。有时评估方法不同甚至可能导致评估结果不同，因此，应该由具体情况决定选用何种方法。信息安全风险评估方法根据计算方法不同可分为定性分析方法、定量分析方法和定性与定量结合的分析方法。

1. 定性分析方法

定性分析方法是一种采用比较广泛的模糊分析方法。这种方法主要依靠专家的知识和经验、被评估对象的相关记录，以及相关走访调查来对资源、威胁、脆弱性和现有的防范措施进行系统评估。它主要通过与被调查对象的深入访谈、各种安全调查表格等方式来确定资产的价值权重，并通过一定的计算方法确定某种资产所面临的风险的近似大小。

定性分析方法的优点有：操作简单易行并且容易理解和实施，不易产生不同的意见，并且能够较方便地对风险程度大小进行排序。缺点是：对有些重要风险级别区分度欠缺，分析结果容易偏向主观性。

定性分析方法很多，包括小组讨论(如 Delphi 方法)、调查、人员访谈、问卷和检查列表等。典型的定性分析方法如主观评分法，其凭借专家的经验等，根据评价标准，让专家判断可能产生的每个风险并赋予其权重。例如，用 0 表示没有风险，10 代表风险很大，0～10 的数字表示风险程度依次加大，然后把全部风险的权重加起来计算出整体风险水平，最后与风险评估基准进行比较，这里以故障树为例进行介绍。

故障树分析法是由美国贝尔实验室的 Watson 和 Mearns 于 1961 年到 1962 年期间首次提出并采用的。故障树分析法源于他们在分析、预测民兵式导弹发射控制系统安全性时的发

现。故障树分析法的主要应用遵循从结果找到原因的原则，将风险形成的原因由总体到部分按树枝形状逐级细化，分析项目风险及其产生原因之间的因果关系，即在前期预测和识别各种潜在风险因素的基础上，运用逻辑推理的方法，沿着风险产生的路径，求出风险发生的概率，并提供各种控制风险因素的方案。

故障树分析法因其强大的逻辑性和形象化等特性，在分析和评估比较复杂系统的风险时很有效。此外，该方法用其固定的流程来分析，并借助计算机辅助建树，其结果有系统性、预测性和准确性的特点。在项目评估中，故障树分析法对风险管理效率的提高作用很大。

2. 定量分析方法

定量分析方法基于定性分析方法，用数学的方法分析处理已经量化的各项指标，得出系统安全风险的量化评估结果。其思想是对构成风险的各个要素和潜在损失的水平赋以数值，进而来量化风险评估的整个过程和结果。常用的定量评估方法如下。

(1) 决策树法，是一种直观运用概率分析的图解法。如果已知各种情况的发生概率，就可以通过构成决策树求取净现值的期望值的概率，以此评价项目风险并判断其可行性的决策分析方法。决策树方法因其形象化、清晰有效和特有的结构模型的特点非常利于项目执行人员进行集体分析和探讨。

(2) 模糊评价法，是对模糊系统进行分析的基本方法之一，多用于目标决策。对在评估过程中带有主观性的问题及客观遇到的模糊现象，模糊评价都可以进行有效的处理。模糊评价是在模糊条件下，考虑多种因素影响，为了某一目的而反对事物做出决策的一种综合决策方法。其利用模糊数学中的模糊变换原理和最大隶属度原则对被评价事物相关的各个因素做出的综合评价。该评价方法着眼于各个相关因素。

(3) 层次分析法(Analytic Hierarchy Process，AHP)，由美国著名的运筹学家 T. L. Satty 教授在 20 世纪 70 年代提出，是一种有效、简便、灵活处理不易定量化而又实用的定向与定量相结合的、层次化的多准则决策方法。层次分析法的核心是将负责的问题进行层次化，将原问题简单化并在层次基础上进行分析，它把决策者的主观判断量化，以数量形式进行表达和处理，通过定量形式的数据将定性和定量分析相结合从而帮助决策者进行决策。

3. 定性和定量结合的分析方法

定性分析要求分析者具有一定的能力和经验，分析基于主观性，其结果很难统一；而定量分析依赖大量的统计数据，分析基于客观，其结果很直观，容易理解。另外，信息安全风险评估是一个复杂的过程，涉及多个因素、多个层面，具有不确定性，它是一个多约束条件下的多属性决策问题。而在实际评估中，有些要素的量化很容易，而有些却是很困难甚至是不可能的。如果单纯使用定性或定量的方法，对风险有效的评估则是很难的。因此将两种方法相结合进行风险评估才能得出更有效的结论。

10.2.4.2 信息安全风险评估工具

风险评估工具是随着人们在对信息安全风险评估不断认识，以及对评估过程不断完善的过程中逐渐发展的。随着人们对信息资产的深入理解，发现信息资产不只包括存在于计算机环境中的数据、文档，信息还在各种载体中传播，包括纸质载体、人员等，因此信息安全包括更广泛的范围。同时，信息安全管理者发现解决信息安全的问题在于预防，而不是简单地防御，因此，许多国家和组织都建立了针对预防安全事件发生的风险评估指南和方法。基于这些方法，同时也开发了大量的风险评估工具，如 CRAMM、RA 等。

目前风险评估过程常用的是一些专用的自动化的风险评估工具，无论是收费的还是免费的，此类工具都可以有效地通过输入数据来分析风险，最终给出对风险的评价并推荐相应的安全措施。对于目前最常见的自动化评估工具的比较如表 10.1 所示。

表 10.1　常见的自动化评估工具的比较

工具名称	COBRA	RA	CRAMM	@RISK	BDSS
组织/国家	C&A/英国	BSI/英国	CCTA/英国	Palisade/美国	The Integrated Risk Management Group/美国
体系结构	C/S 模式	单机版	单机版	单机版	单机版
采用方法	专家系统	过程式算法	过程式算法	专家系统	专家系统
定性/定量算法	定性/定量结合	定性/定量结合	定性/定量结合	定性/定量结合	定性/定量结合
数据采集形式	调查问卷	过程	过程	调查问卷	调查问卷
对使用人员的要求	不需要有风险评估的专业知识	依靠评估人的知识和经验	依靠评估人的知识和经验	不需要有风险评估的专业知识	不需要有风险评估的专业知识
结果输出形式	结果报告：风险等级与控制措施	风险等级与控制措施（基于 BS7799 提供的控制措施）	风险等级与控制措施（基于 BS7799 提供的控制措施）	决策支持信息	安全防护措施列表

从表 10.1 可以看出，这五种著名的自动化评估工具从发布的组织/国家、体系结构、评估所采用的方法、风险分析计算的方法等几方面来看，既有其共同点又有其自身的特点。

（1）从发布的组织/国家来看，主要是英国和美国等国家，我国现在还没有一种自动化评估工具软件得到国际上的认可。

（2）从体系结构来看，这些工具具有一定的共同点，大都是单机版，只有 COBRA 采用了 C/S 模式，采用这种模式可以将数据库和客户端进行分离，保证了系统的可维护性，实践中只要不断丰富完善数据库就可以对工具进行更新。

（3）评估方法和数据采集方式的使用是具有相关性的，RA 和 CRAMM 是使用传统的过程式算法，造成它们的数据采集方式都是过程式的，这种方法具有流程单一、不能适应实际评估目标情况的缺点。而更多的工具采用了专家系统和调查问卷的方法，专家系统可以使评估工具发挥更大的作用，结合调查问卷和背后强大知识库的支持，可以适应实际评估中多变的情况，更好地完成对被评估系统风险要素情况的采集，并且可以更有效地分析出被评估系统的风险状况。

（4）对使用者的要求是不断降低的趋势，大多数自动化评估工具不需要具有专业风险评估知识的使用者。

（5）从结果输出来看，各种工具的输出都侧重了不同的方向，不过根据被评估系统的风险状况提出有效的控制措施是基本的功能。

10.3　信息安全审计

审计（audit）是由专设机关依照法律对国家各级政府及金融机构、企业事业组织的重大项目和财务收支进行事前和事后审查的独立性经济监督活动。审计是一种经济监督活动，经济

监督是审计的基本职能。通常，审计主要指财务审计。但是随着企业信息系统的广泛应用和计算机网络的普及，企业的经营模式发生了根本性的变革，企业传统的内部审计也迎来了巨大的挑战，IT 审计成为审计的重要内容，审计的内容和审计的方式发生了重要变化。中国内部审计协会 2013 年发布的《第 2203 号内部审计具体准则——信息系统审计》，对信息系统审计提出了具体要求，其中也包括信息安全审计的内容。信息系统审计也称为 IT 审计，信息安全审计是其重要内容，要做好 IT 审计必须深入了解信息安全。特别是随着信息化的深入，信息安全审计重要性越来越突出。

10.3.1 信息安全审计概述

信息安全审计是 IT 审计和信息系统审计的重要组成部分。国家审计机关已经开展的信息系统审计工作中，信息安全审计是其重要内容之一。我国银监会、证监会等多个行业监管部门均已出台相关政策，要求建立信息安全审计制度，定期实施信息安全审计。信息安全审计师已经成为一种重要的职业。信息安全审计师（Certified Information Security Professional-Auditor，CISP-Auditor）是中国信息安全测评中心（China Information Technology Security Evaluation Center，CNITSEC）在 CISP 现有人员资格认证注册工作的基础上，于 2010 年推出的一项信息安全专业人员资格认证项目，是国家对信息安全审计人员资质的最高认可。中国信息安全测评中心鼓励从事信息安全审计和信息系统审计岗位的工作人员取得国家注册信息安全审计师认证资格。

信息安全审计师注册人员应掌握两部分内容：信息安全基础知识、信息安全审计知识。信息安全审计知识将重点关注传统财政财务收支审计、信息系统审计的方法和流程、信息安全控制措施的审计实务，以及在实际审计过程中可能用到的审计工具。在整个注册信息安全审计师的知识体系结构中，共包括信息安全保障概述、信息安全技术、信息安全管理、信息安全工程、信息安全标准法规、信息安全审计基础、信息安全审计方法与流程、信息安全控制审计实务、信息安全计算机辅助审计技术这九类知识类。

下面介绍有关信息安全审计的两个概念。

（1）独立性，是审计部门的基本原则之一。绝大多数的审计部门都会强调，审计的独立性是审计成功的关键之一，是审计结果权威性和公正性的基础。

审计独立性指审计师不受那些削弱或纵使有合理的估计仍会削弱审计师做出无偏审计决策能力的压力及其他因素的影响，其对审计工作来讲至关重要。因为涉及市场经济的利益公平，独立性被职业界视为审计的灵魂。

（2）内部控制（internal controls），指一个单位的各级管理层，为了保护其经济资源的安全、完整，确保经济和会计信息的正确可靠，协调经济行为，控制经济活动，利用单位内部分工而产生的相互制约，相互联系的关系，形成一系列具有控制职能的方法、措施、程序，并予以规范化、系统化，使之成为一个严密的、较为完整的体系。审计的主要任务就是改善企业的内部控制状态。

内部控制的类型有：预防性控制、侦测性控制、反应性控制。这三种内部控制的作用分别是阻止不良事件的发生、事件发生后进行侦测，反应是介于二者之间的控制。例如，软件变更的控制、访问控制、灾备控制等。

10.3.2　信息安全审计的作用

在各行各业，信息安全在 IT 管理中的关注度越来越高，企业对信息安全的资金投入也越来越大。信息化初期，仅是投入单一的安全技术与产品，目前已过渡到信息安全的整体解决方案。同时，IT 外包也是行业发展趋势，信息安全审计工作除了企业自身进行内审外，邀请具有适当资质的、独立的第三方进行外审，也是未来发展的趋势。

实施信息系统安全审计可以起到以下作用。

(1) 驱动业务增值。组织机构可通过审计，确保信息系统所产生数据的真实性、完整性和可靠性，切实落实合适的 IT 治理模式，使 IT 治理成为组织机构的战略性资源，为业务增值。

(2) 提升 IT 管理。通过对网络或系统的脆弱性、有效性等进行测试、评估和分析，发现控制缺陷或漏洞，并提出整改加固的建议，可促进被审计机构提高 IT 管理水平，从而提高业务经济效益。

(3) 健全内控制度。通过审计，对信息系统的管理流程进行诊断，客观中立地指出 IT 建设和运维过程中的风险，帮助组织机构建立健全的内控制度。

10.3.3　信息安全审计的分类

按照不同的审计角度和实现技术，信息安全审计可以分为主机审计、日志审计、应用系统审计、合规性审计、网络行为审计、集中操作运维审计等。

(1) 主机审计：通过在主机服务器、用户终端、数据库或其他审计对象中安装客户端的方式进行审计，可以实现对安全漏洞、入侵行为、上网行为及操作内容、向外复制数据等的审计。

(2) 日志审计：通过日志接口从网络设备、主机服务器、用户终端、数据库或应用系统等中收集日志并进行分析，最终形成不同的审计报表。

(3) 应用系统审计：对用户的登录、操作、退出等行为通过内部获取或跟踪等方式进行监控或记录，并对这些记录按时间、地址、命令、内容等分别实施审计。

(4) 合规性审计：对信息系统运行过程是否符合法律、法规、标准及相关文件规定进行审计。

(5) 网络行为审计：通过捕获网络数据包，分析或还原其协议，实现对主机服务器、用户终端、数据库或应用系统等的审计。

(6) 集中操作运维审计：对主机服务器、用户终端、网络设备、数据库或应用系统等的运行维护过程进行审计。

10.3.4　信息安全审计的过程

信息安全审计的过程分为 6 个阶段，即计划、实地考察与制作文档、发现问题和验证问题、制定解决方案、起草并发布报告、问题跟踪。

(1) 计划：在开始审计之前，必须确定计划审计什么。计划的目标是确定审计的对象和范围，一个有效的计划是审计成功的关键。

(2) 实地考察与制作文档：根据信息安全审计的计划，针对审计对象和范围进行实际运行体系的考察，了解客户需求并列出检查清单。

(3) 发现问题和验证问题：实施信息安全审计，发现运行体系存在的信息安全问题并进行验证，确定安全问题的对象和成因。

（4）制定解决方案：对信息安全问题进行评估，结合现有的信息安全防控措施，经过专家与技术人员讨论，制定综合解决方案。

（5）起草并发布报告：确定信息安全风险性质及等级，制定进度表，发布信息安全问题、解决方案的报告文件。

（6）问题跟踪：将解决方案付诸实施，追踪问题，直到问题被解决。

最后，召开会议，审计师对整个信息安全审计过程进行分析、讨论。

10.3.5 信息系统安全审计的发展

1. 国内早期信息系统安全审计发展的两个阶段

与西方发达国家相比，我国的IT安全审计工作起步比较晚，与之关联的安全审计技术、安全审计准则和审计制度等尚待进一步完善。我国的信息系统安全审计发展经历了两个阶段。

（1）信息系统安全审计的引进阶段。1999年，财政部发布了《独立审计准则第20号——计算机信息系统环境下的审计》，该准则在部分内容上参考并借鉴了国外的针对审计方面的研究成果。这是国内首次提出要针对计算机信息系统实施审计的要求。同年，国家质量技术监督局颁布了《计算机信息系统　安全保护等级划分准则》(GB 17859—1999)，该准则用于实施计算机信息系统安全保护等级及测评，是实施安全等级保护管理的基础性标准，其中明确要求了针对不同安全级别的信息系统，实施不同安全等级的安全控制要求，来防范未授权的访问，以及维护信息系统受到破坏时候的访问审计记录。

（2）2005—2009年信息系统安全审计成长发展期。这一时期，Internet在国内得到了快速的发展和普及，随之而来的信息安全问题不断涌现，在这样的背景下，国内信息系统安全审计得到了足够的重视和长足的发展。国家政府部门、能源行业、金融行业、电信行业相继推出了适合于自己行业特点的信息系统风险管理标准、制度及政策法规，这些活动和策略支撑并推动了信息安全审计的快速发展。公安部于2005年10月颁布了82号令，标题为《互联网安全保护技术措施规定》，该规定要求“互联网服务提供者和连接到互联网上的企事业单位必须记录、跟踪网络运行状态、记录网络安全事件等安全审计功能，并应当具有至少保存六十天记录备份的功能。”。2006年，国务院信息化工作办公室，国家保密局、公安部、国家密码管理局、联合统一制定并发布了《信息安全等级保护管理办法(试行版)》，该办法要求在对信息系统进行定级、建设、整改、测评等工作的时候要严格安全相关行业及国家技术标准进行。作为信息安全等级保护的重要基础标准的《信息系统安全等级保护基本要求》，在该要求中，安全审计能力在不同安全等级的信息系统审计过程中也不尽相同。例如，需要针对安全事件、用户行为进行安全记录，并且该安全记录可以被统计分析，并生成报告和表格。2006年，国家保密局发布了《涉密信息系统分级保护技术要求》，简称BMB17—2006号文件，该文件中要求对于不同涉密单位的信息系统，不同级别的信息系统，需要采用相对应的审计措施。2006—2009年，在多个行业的信息系统安全建设中，安全审计被要求作为一项重要的工作要求。2008年6月，审计署、保监会、财政部、证监会等联合发布了《企业内部控制基本规范》，并于2011年1月1日起正式实施，主要针对境内外同时上市的中小公司，是我国审计领域的里程碑式的举措，由于该规范类似于美国的SOX法案，因此，被称为中国的“SOX法案”。2009年3月，银监会发布了《商业银行信息科技风险管理指引》，该指引主要是为了加强商业银行信息系统的风险管理，确保其重要信息系统按照规范的要求满足风险管理，降低风险等级。其中该管理指引明确要求

了内外部审计在其中的作用，并且明确安全审计要贯穿在信息系统活动及生命期过程中。在信息化不断发展的当今，为确保信息系统安全稳定运行，安全审计成为不可或缺的重要技术手段。根据以上信息安全审计的发展概述，各个行业和在信息化发展过程中存在的不同，因此，相对应的安全审计的要求和关注点也不一样。而针对政府部门来说，其主要还是关注信息安全等级保护方面的要求，确保信息系统可以满足该等级保护的审计要求。

2. 中国内部审计协会第 2203 号内部审计具体准则：信息系统审计

为了规范信息系统审计工作，提高审计质量和效率，中国内部审计协会提出了第 2203 号准则：信息系统审计准则。该准则适用于各类机构的内部审计人员，内部审计机构以及相关的信息系统审计活动。其他组织或人员接受委托、聘用，承办或参与内部审计业务，也应当遵守本准则。信息系统审计的目的是通过实施信息系统审计工作，对组织是否实现信息技术管理目标进行审查和评价，并基于评价意见提出管理建议，协助组织信息技术管理人员有效地履行职责。

2203 号信息系统审计准则于 2003 年 6 月 1 日正式实施，它包括了基本准则和 10 个内部审计具体准则，并且在第二年发布了 11～15 号沟通准则，以及 5 个内部审计具体准则。从 2005 年到 2013 年 8 月，持续发布了多个实务指南，并且对该准则实施了修订工作，修订后的终稿已于 2014 年 1 月 1 日施行。

在该准则当中，在第二章一般原则中第四条，明确定义了信息系统审计的目的："信息系统审计的目的是通过实施信息系统审计工作，对组织是否实现信息技术管理目标级进行审查和评价。"

另外，在第八条："内部审计人员应当采用以风险为基础的审计方法进行信息系统审计，风险评估应当贯穿于信息系统审计的全过程。"要求审计人员具有相关的信息安全风险评估的知识和技能，能利用相关工具实施基于风险评估的安全审计工作。在准则当中确定了信息技术的管理目标，即组织的信息技术管理目标主要包括：保证组织的信息技术战略充分反映组织的战略目标、提高组织所依赖的信息系统的可靠性、稳定性、安全性及数据处理的完整性和准确性、提高信息系统运行的效果与效率，合理保证信息系统的运行符合法律法规及相关监管要求。从以上分析可以看出，针对信息系统的安全审计是有详细的准则依据，在实施安全审计的过程中需要严格遵守这些准则和要求，才能确保审计工作的客观和准确性。

10.4　本 章 小 结

近年来，信息安全理论与技术发展很快，从传统的加密解密、杀毒软件、防火墙、入侵检测到容忍入侵、可生存性、可信计算、信息保障等的研究，从关注信息的保密性发展到关注信息的可用性和服务的可持续性，从关注单个安全问题的解决发展到研究网络的整体安全状况及变化趋势。信息安全领域进入了以立体防御、深度防御为核心思想的信息安全保障时代，形成了以预警、攻击防护、响应、恢复为主要特征的全生命周期安全管理，出现了大规模网络攻击与防护、互联网安全监管等许多新的研究内容。安全管理也由信息安全产品测评发展到大规模信息系统的整体风险评估与等级保护等。在发展信息安全技术的同时，加强信息安全管理和信息安全审计具有重要的意义。

思 考 题

1. 简述“三分技术、七分管理”的含义。
2. 什么是 PDCA 模型？从 PDCA 模型角度如何理解 ISMS 过程？
3. 什么是信息安全风险评估？其包含哪些要素？
4. 信息安全风险评估有哪些策略？
5. 简述信息安全风险评估流程。
6. 从定性和定量角度，信息安全风险评估有哪些方法？
7. 当前信息安全风险评估有哪些工具？
8. 简述信息安全审计的过程。
9. 信息安全审计有哪些分类？